信息安全测评与风险评估

4.5 漏洞扫描与结果分析

授课教师：杨迎



目录

CONTENTS

01 案例导入：修了 3 个"高危"，最后发现跑错报告

02 关键知识：漏洞扫描怎么跑、报告怎么读

03 动手实验：西普平台漏洞扫描顺序与结果分析

04 复盘结果：分析报、整改优先级与下节预告

Part.01

例导入——修了 3 个"高危"，最后发现是误



案例导入：修了 3 个"高危"，业务挂了，最后发现是误报

先想一个问题：扫描报告说有高危漏洞，是不是就该立刻修？

某政务服务平台在等保测评前，自行使用漏洞扫描工具进行了一次“全面扫描”。结果如下：

- 扫描发现“高危漏洞”15个，“中危漏洞”42个
- 安全负责人看到报告后，按照CVSS评分最高开始修复
- 修复了3个“高危漏洞”后，业务系统出现异常——无法正常登录
- 紧急回滚后，测评机构进场，发现那3个被修复的“漏洞”其实是扫描工具的误报

先想一想（30 秒）

Q1 1. 扫描器凭什么说这是漏洞？（它是比对特征，

（基于规则匹配的特征码扫描，难免与正常配置“撞车”）

Q2 2. 不修怕出事、修了怕宕机，你怎么先确认它是

Q3 3. 拿到一份报告，你的第一步应该做什么？

学习目标

学完这一节，你应该能做到：



理解 说清扫描是怎么工作的：拿已知漏洞特征去比对，所以它为什么会误报



掌握 在西普实验平台上建任务、配目标、跑扫描、导出报告，走完整套流程



能够 看懂 CVSS 评分与风险等级，动手验证哪几条其实是误报



能够 把扫描结果对上等保条款，填进分析表做四档判定



具备 按"能不能被利用 + 影响多大"排出整改优先级

Part.02

关键知识——扫描怎么跑、报告怎么读



漏洞扫描——在等保测评中的定位

GB/T 22239-2019 8.1.4.4 e）安全计算环境——入侵防范：应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞。

等保测评中的三种技术手段

方法	定义	在等保测评中的作用
访谈	与管理人员交流，获取证据	了解安全管理制度、人员配置
核查	查验文档、设备配置	验证配置是否符合基线
测试（含漏洞扫描）	使用工具产生结果，与预期比对	发现脆弱性、验证安全措施有效性

漏洞扫描在测评中的具体位置

1

测评阶段

现场测评 → 技术测试环节

2

对应标准

GB/T 22239安全计算环境 → 入侵防范

3

输出物

《漏洞扫描报告》

（每个系统1份，含主机+Web）

漏洞扫描的核心原理

核心定义

漏洞扫描是基于已知的漏洞数据库，通过模拟攻击行为检测目标系统是否存在可被利用的缺陷的自动化过程。

关键点

漏洞扫描是“基于特征码的匹配”——工具只能发现已知漏洞，无法发现0day。

技术原理三步走

1. **端口扫描**
   探测目标开放端口
   使用Nmap等工具
2. **服务识别**
   通过协议特征判断版本
   例：OpenSSH 7.4
3. **漏洞匹配**
   与CVE/NVD漏洞库对比
   生成报告

常见扫描类型

主机漏洞扫描

检查操作系统补丁、配置错误

工具：Nessus、Lynis

Web应用扫描

模拟SQL注入、XSS攻击

工具：AWVS、Burp Suite

数据库扫描

检查权限配置、弱密码

工具：DBScan

用什么扫——常见扫描工具与本课选择

素材4：Nessus与OpenVAS对比（选

工具	类型	特点	适用场景
Nessus	商业（有免费版）	漏洞库更新快、覆盖面广、界面友好、报告能力强	企业级、合规要求高
OpenVAS	完全开源	无授权费用、社区活跃、支持大规模扫描	成本敏感、教育/实验环境
Nmap	开源	网络发现、端口扫描、服务识别	信息收集、资产发现

本课用什么：西普实验平台跑扫描、出报告（漏洞扫描工具使用 +

扫描怎么跑——西普平台一次完整扫描的六步

扫描端 西普实验平台（10.11.0.70）漏洞扫描实验环境

扫描目标 平台提供的靶机 / 预置漏洞主机（只扫平台给的）

01 登录并进入扫描实验
账号=学号，密码=学号+1q2w

02 新建扫描任务
选"系统漏洞扫描"模板

03 填目标地址
填平台给的靶机 IP，绝不填校外地址

04 启动扫描
看进度条，约 5~10 分钟，别中途关页面

05 看结果列表
按 Critical / High / Medium / Low 分档看

06 导出报告
导出 PDF，后面分析表要用

看报告时盯三件事

等级怎么分

Critical 能被直接利用拿权限，High 还需要条件配合

详情看什么

漏洞描述、影响版本、修复建议，三样缺一不可

像不像误报

只报版本号、给不出利用路径的，先按疑似误报处

Part.03

动手实验——西普平台漏洞扫描 + 结果分析



实验①做什么——跑一次完整扫描（V1 → V2）

项目	说明
实验名称	漏洞扫描操作（西普平台：漏洞扫描工具使用 + Windows 漏洞扫描）
实验环境	西普实验平台（10.11.0.70）「漏洞扫描与结果分析」实验：V1 漏洞扫描工具使用 → V2 Windows 漏
操作步骤	1 登录平台，进入「漏洞扫描与结→ 2 熟悉任务配置、模板选择与结果查看，跑通一次扫描→ 3 进入「Windows 漏洞扫→ 4 启动扫描，查看进度→ 5 查看结果，导出报告，选择高危及以上条目并逐条留
实验产出	高危及以上漏洞列表截图 + 导出的报告（实验②分析要用）

素材3：OpenVAS 快速操作手册.docx

扫描跑不动？先查这张表

问题	怎么解决
登不进平台	确认是 http://10.11.0.70，账号=11 位学号，密码=学号+1q2w；换浏览器再试
扫不动 / 0 结果	先确认靶机 IP 填对、平台提供的靶机已开机，再检查模板是否选错
进度卡住不动	不要关页面，等 5~10 分钟；超过 15 分钟仍不动再重跑一次并截图
报告导出失败	换 PDF 格式重试；实在不行就分段截图高危列表，注明"导出失败"
高危多到不知从哪下手	先按 CVSS 降序，只看 Critical 和 High，中低危先记录不展开

报告怎么读——CVSS 评分与风险等级

风险等级分类（CVSS评分体系）：

Critical（严重）

CVSS分值：9.0-10

建议时限：24-48小时

High（高危）

CVSS分值：7.0-8.9

建议时限：3-7天

Medium（中危）

CVSS分值：4.0-6.9

建议时限：7-30天

Low（低危）

CVSS分值：0.1-3.9

建议时限：30-90天

报告关键字段解读：

字段	含义	关注要点
漏洞名称	漏洞的CVE编号/描述	确认是否知名漏洞（如永恒之蓝）
影响主机	哪些IP/系统受影响	判断是单点问题还是共性问题
风险等级	CVSS评分	确定修复优先级
漏洞描述	漏洞的技术细节	理解漏洞原理
修复建议	推荐的修复方法	判断是否可操作

这条漏洞是真的吗——误报怎么验

误报的常见原因

原因	示例	验证方法
版本号误判	基于banner识别版本，与实际不符	登录系统确认实际版本
配置误判	扫描工具认为默认配置=不安全	检查实际配置是否有补偿措施
网络环境干扰	防火墙、IDS导致响应异常	在本地网络重新扫描
漏洞已修复但未更新扫描缓存	补丁已安装但扫描库未及时更新	对比补丁安装记录

验证误报的三步法

1. **查看漏洞详情**
   阅读扫描报告中的“漏洞描述”和“验证方法”
2. **手动验证**
   登录目标系统，检查配置文件/补丁状态
3. **对比确认**
   使用另一款工具交叉验证，或咨询运维人员

扫描结果怎么落到等保条款

等保测评中漏洞扫描结果的应用场景：

等保测评维度	漏洞扫描发现的对应问题	测评判定
安全计算环境-身份鉴别	存在弱口令漏洞	影响身份鉴别合规性
安全计算环境-入侵防范	存在未修复的高危漏洞	直接导致入侵防范不符合
安全区域边界-访问控制	开放了高危端口（如3389、22）	边界防护策略不严
安全区域边界-入侵防范	扫描发现可利用漏洞	说明入侵防范能力不足

关键认识： 漏洞扫描报告中的高危漏洞，通常直接对应等保测评中的“不符合项”。

实验②做什么——结果分析与出表

项目	说明
实验名称	漏洞扫描结果分析（西普报告 + 分析表判定）
实验环境	实验①导出的报告 + 《漏洞扫描结果分析表》（素材2）

素材1：模拟漏洞扫描报告（用于实践

- 分析四步

01

提：挑出高危及以上条目，一条一行

02

分：按 CVSS 与"能不能被利用"分

03

对：一条一条对上等保条款（8.1.4.4 入侵

04

定：给出整改优先级与完成期限

实验③怎么判——分析表录入与四档判定

填什么	怎么填	示例（一条高危漏洞）
测评对象	目标 IP + 系统/服务 + 版本	10.11.x.x / Ubuntu 16.04 / vsftpd 2.3.4
测评项	条款编号 + 名称	8.1.4.4 e) 入侵防范-已知漏洞
漏洞名称	抄报告里的原文，别自己改名	vsftpd 2.3.4 Backdoor Command Execution
风险等级	按报告里的 CVSS 分档抄	Critical / CVSS 10.0
是否误报	写"已验证为真"或"疑似误报"，并说明怎么验的	已验证为真：手工连接可触发
证据编号	填截图文件名，与截图包对应	V2-03.png
符合性判定	四选一：符合 / 部分符合 / 不符合 / 不适用	不符合

实验④交什么——成果与提交前自查

类别	要求
必交 1	《漏洞扫描结果分析表》：高危及以上条目逐条填（等级 + 是否误报 + 四档判定 + 整改建议）
必交 2	扫描取证包：任务配置页、结果列表、导出的 PDF 报告，编号与分析表一一对应
操作步骤	1 平台登录与实验列表截图 → 2 命名：班级-学号-姓名-4.5实验_分析表.docx + 班级-学号-姓名-4.5实验_扫描取证包.zip → 3 提交至学习通 → 4 自查：□ 每项漏洞已填写等级、是否误报、四档判定、整改建议 → 5 □ 整改建议不得照抄模板，须结合本次实验环境与实际操作过程而提出；□ 压缩包内只含本人实验文件，不含他人或平台
评分看点	扫描操作 30% + 报告解读 25% + 判定与描述 25% + 职业素养 20%

素材3：OpenVAS 快速操作手册.docx

Part.04

回顾与拓展——误报、整改优先级与下节预告



漏洞管理闭环（拓展知识）

漏洞扫描只是起点，完整的漏洞管理需要形成闭环。漏洞管理六步法：



等保2.0要求：

应定期开展安全测评，发现的安全漏洞应及时修补或采取其他有效补救措施。

职业提醒——没有授权的扫描，就是攻击

授权

- 进行漏洞扫描必须先获得授权（书面）
- 未经授权扫描他人系统属于违法行为
- 等保测评中的扫描必须在授权范围内进行

客观

- 如实记录扫描结果
- 不隐瞒高危漏洞，不夸大风险等级

负责

- 扫描结果直接影响客户的安全判断
- 误报的识别和解释，体现测评师的专业水准

一句话：你删掉的那条高危，可能就是下次被攻破的那个口子。

知识点回顾

漏洞扫描与结果分析

- **一、漏洞扫描原理**
  - 基于漏洞库的特征匹配
  - 类型：主机/Web/数据库扫描
- **二、本讲用什么**
  - Nessus（商业，功能强）
  - OpenVAS（开源，成本低）
- **三、报告解读**
  - CVSS风险等级（Critical→Low）
  - 名称/影响主机/风险等级/修复建议
  - 误报识别：版本误判、配置误判
- **四、与等保测评的关联**
  - 对应标准：8.1.4.4 入侵防范
  - 高危漏洞→等保不符合项
- **五、漏洞管理闭环**

资产识别 → 扫描 → 分析 → 修复 → 验证 → 报告

课后作业

素材2：漏洞扫描结果分析表.docx

必做	用素材2 完成《漏洞扫描结果分析表》（基于你自己导出的报告），连同截图包提交至学习通
必做	完成项目4. 5在线测试（选择题+判断题，共20题）
选做	在西普平台再跑一次不同模板的扫描，对比两次结果差异，写 5 行说明
预习	预习任务5“安全管理测评”相关内容

下节课预告：任务5：安全管理测评

预告内容

1. 安全管理测评五个核心维度
   制度、机构、人员、建设、运维
2. 文档核查方法
3. 模拟人员访谈

课前准备

- 复习GB/T 22239“安全管理”章节
- 阅读安全管理相关制度文件示例

感谢观看

